

The BeEF server is then used to run commands in the “hooked” browser using the inserted code in the browser. This enables one to gain control over the browser. To hook the web browser, we need the victim to execute the JavaScript file of BeEF called “hook.js,” in the vulnerable web app. There are multiple ways to get the victim’s browser hooked.

5. Running Commands in the Browser

After hooking the victim’s browser, numerous built-in commands can be executed from the victim’s browser to get vital Information. The commands can be used to get visited domains, get visited URLs, enable or disable the webcam, get all cookies in the browser, grab all contacts associated with the google account in the browser and even take screenshots of the webpage.

On executing any of the built-in commands into the hooked up victim browser, a dialog box opens up on the screen of the browser asking for permissions. For example, running the Camera command will display an Adobe Flash dialog box on the screen of the user, asking, “Allow Webcam?” If they click “Allow,” or “Agree”, then it will begin to take pictures from the webcam and return it to the BeEF server.

Since it is unlikely that the victim will enable permissions on the web browser, therefore the permissions text can be customized. For instance, instead of asking for permissions, the dialog box could read, “You have just won 10 lakh rupees! Click here to collect your winnings!” or “Click here to update your software and keep your computer secure.” Such messages may motivate the user to grant permission.

6. Getting Cookies

After hooking up the browser, there are infinitely many possibilities to exploit Information from the victim. For instance, if cookies from the victim’s browser are required, go to “Chrome Extensions” and select “Get All Cookies”. This is illustrated in the screenshot below. Clicking on the “Execute” button to the bottom right will enable the collection of all the cookies from the browser. Since we have access to the browser cookies, we also gain access to their websites as.

Maltego

Maltego is an interactive data-mining tool developed by Paterva and shipped by Kali Linux. It provides directed graphs that are used for link analysis. Maltego is used for finding relationships between pieces of Information